



All Findings, No Context

Tales from Both Sides of the Firewall

Agenda

- The **Consultant** Mindset
- Crossing the Border: Becoming an **Insider**
- The **Context** Gap: Why External Reports Typically Fall Short
- Building **Influence**, Not Just Findings
- Security as a **Product**, Not a Project
- Lessons **Learned** & Ongoing **Challenges**
- Q&A: Ask Me **Anything!**

whoami - "\$(\$Env:USERDOMAIN)\\$(\$Env:USERNAME)" / ls -ld \$HOME



Tom Houiellebecq
Team Lead – Cyber Security Engineering



The *Consultant* Mindset

The *Consultant* Mindset



🧠 Key Revelations:

External -> *Internal*

- Consultants operate in a **snapshot world** – internal teams live in a **messy, continuous movie**.
- External assessments are often **technically accurate**, but **contextually incomplete**.

Red Team -> *Blue Team*

- Red is about **what's possible**; blue is about **what's probable and painful**.
- Don't just break it – look to try explain **impact in operational terms**.
- **Empathy** helps blue teams anticipate better - and red teams report more effectively.

Crossing the Border: Becoming an *Insider*

Crossing the Border: Becoming an *Insider* [Not Threat 😊]



🧠 Key Revelations:

External -> *Internal*

- Get to know system ownership boundaries. Many systems/services exist in a "no man's land."
- Internally, security is less about fixing everything and more about fixing the right things.
- Security inside a business is a **balancing act** between risk reduction, operational impact, and business goals.

Red Team -> *Blue Team*

- Red shows the gaps.
- Blue shows the **real-world fatigue** those gaps live in. Clear documentation, debriefs, and shared insights turn red team value into **blue team improvements**.

The *Context* Gap: Why External Reports Fall Short

The *Context* Gap: Why External Reports Fall Short



🧠 Typical Real-World Example:

"TLS Misconfiguration - High Risk" - External Consultant Report Summary:

Finding: The application supports multiple weak cipher suites and does not implement HTTP Strict Transport Security (HSTS).

Risk Rating: **High**

Recommendation: Disable weak ciphers and enforce HSTS headers across all services.

CVE References: CVE-2016-2183, CVE-2017-3731

🧐 Key Revelations:

- Contextual Awareness Is **EVERYTHING**
- **Action-Oriented** Recommendations
- Risk Ratings Based on **Business Impact**
- Consider Including **Exploitability** vs. **Exposure**
- Improve Report **Format Usability**

Building *Influence*, Not Just Findings

Building *Influence*, Not Just Findings



💡 Real-World Example:

On a pentest:

- **Compromised** a frontend by chaining a known XSS in a React-based dependency from a community plugin.
- The devs didn't know it had been **deprecated**.
- Gap quickly discovered how **infrequently dev teams review transitive dependencies**.

🧐 Key Revelations:

- As a consultant, your authority comes baked into the contract.
- Internally, it's about **influence, relationships, and credibility**.
- Security change require **cross-functional buy-in**.

Security as a *Product*, Not a Project

Security as a *Product*, Not a Project



🧠 Real-World Example:

We initiated a threat modeling program for all new feature rollouts. Initially, it was seen as "*extra work*." We created templates integrated with design documents. Adoption improved, and product teams reported they were *catching bugs earlier*.

🧐 Key Revelations:

- Think of developers as *customers*, and security as a *service layer*.
- Integrate security into native workflows, *as far left as possible* (e.g., Jira, PRs, CI/CD pipelines).
- Think in features: *secure defaults*, *usable guardrails*, *integrated feedback*.
- Make security the *path of least resistance*.

Lessons *Learned* & Ongoing *Challenges*

Lessons *Learned* & Ongoing *Challenges*



⚙️ Key Takeaways:

Mature security blends **external excellence** with **internal alignment**.

- **Metrics Change**

External = findings closed.

Internal = risk reduction, incident prevention, maturity growth.

- **Culture Matters**

Security must embed into product culture, not exist in parallel.

- **You Still Need External Input**

Red teaming, pentests, audits, fresh eyes are essential - but only useful when **grounded in internal context**.

Q&A: Ask Me
Anything!

Many Thanks For Joining!



Thomas Houillebecq
Cyber Security Engineering Team
Lead at Digitec Galaxus AG



DG OnlyFans



DG VDP



DG Jobs

